

AI Incident Response Plan

Template - Generic / Cross-Industry | Aligned to NIST AI RMF & ISO/IEC 42001

Document Type	AI Incident Response Plan
Template Version	1.0
Document Owner	AI Governance Function
Applies To	All AI systems deployed by the organisation
Regulatory Alignment	NIST AI RMF (Manage) · ISO/IEC 42001 Clause 10
Review Frequency	Annual / Post-Major Incident
Status	Active
Classification	Anonymised – Portfolio Use Only

This plan must be activated immediately upon detection of any AI incident. Do not delay reporting pending investigation. When in doubt — report.

1. Purpose & Scope

This AI Incident Response Plan defines the procedures for detecting, reporting, investigating, containing, and resolving incidents involving AI systems. It ensures that AI failures, harmful outputs, and compliance breaches are handled consistently, swiftly, and with appropriate accountability.

1.1 What Constitutes an AI Incident

- AI system produces factually incorrect, harmful, biased, or misleading outputs
- AI system behaves unexpectedly or outside its defined operating parameters
- AI system causes or contributes to a decision that harms an individual or group
- Hallucination or fabricated output is acted upon before detection
- AI system processes data without appropriate consent or legal basis
- Personal data breach involving an AI system or AI-processed data
- Unauthorised access to AI system outputs, models, or training data
- AI system used outside its intended scope or by unauthorised users
- Model performance degrades significantly below accepted thresholds
- Third-party AI provider suffers a security or data incident affecting the organisation

2. Incident Severity Classification

Severity	Definition	Examples	Response SLA
P1 - Critical	Immediate serious harm to individuals, legal breach, or systemic AI failure affecting core operations.	Personal data breach; AI decision causing individual harm; system-wide hallucination affecting live users; regulatory breach	Immediate - within 1 hour. Escalate to AI Governance Lead, DPO, and senior leadership simultaneously.

Severity	Definition	Examples	Response SLA
P2 - High	Significant harmful or incorrect outputs; material compliance risk; high-impact operational disruption.	Repeated hallucinations in production; biased outputs affecting a group; RBAC failure exposing summaries to wrong users	Within 4 hours. Escalate to AI Governance Lead and Model Owner.
P3 - Medium	Isolated output errors with limited impact; process deviation; minor compliance gap.	Single incorrect summary; missed action item affecting one team; low-confidence output not flagged correctly	Within 24 hours. Log and assign to Model Owner for investigation.
P4 - Low	Minor anomaly or quality degradation with no material impact. Informational.	Slightly lower ROUGE-L score; formatting inconsistency in output; delayed delivery within acceptable tolerance	Within 5 business days. Log and monitor; no immediate escalation required.

3. Incident Response Phases

Phase 1: Detection & Identification

Incidents may be detected by: automated monitoring and alerting; user reports; quality spot-checks; third-party notification; or internal audit.

- Anyone detecting a potential AI incident must report it immediately - do not attempt to resolve it quietly
- Reporter completes the Initial Incident Report form (Section 6) and submits to the AI Governance team
- AI Governance team confirms whether the event qualifies as an incident and assigns severity
- If P1 or P2: immediate escalation path activated (Section 4)

Phase 2: Containment

Containment is the first priority. Stop the harm before investigating the cause.

- Isolate or suspend the affected AI system or workflow if continued operation risks further harm
- Disable automated delivery of AI outputs if outputs cannot be verified as safe
- Revoke or restrict access to affected data or outputs if a data breach is suspected
- Notify affected users or stakeholders if they may have received harmful or incorrect AI outputs
- Preserve all logs, outputs, and system state for investigation - do not delete or alter
- For P1 data breaches: DPO must assess whether regulatory notification is required within 72 hours (GDPR)

Phase 3: Investigation & Root Cause Analysis

- Incident Lead assigned by AI Governance Lead (for P1/P2) or Model Owner (for P3/P4)
- Collect and preserve: AI outputs involved; input data; system logs; model version; prompt/configuration
- Reproduce the incident in a safe environment where possible
- Identify root cause across categories: data quality; model failure; prompt/config error; integration failure; process gap; human error
- Assess scope: how many outputs affected, how many users/individuals impacted, what decisions were made

- Document all findings in the Incident Investigation Record (Section 7)

Phase 4: Remediation & Recovery

- Define corrective actions addressing root cause - not just symptoms
- Test fixes in staging environment before redeployment
- Re-run relevant validation test cases to confirm fix is effective
- Update AI Risk Register with new or revised risks identified during investigation
- Update model card if limitations or failure modes are newly identified
- Obtain sign-off from AI Governance Lead before restoring full system operation
- Communicate resolution to affected users and stakeholders

Phase 5: Post-Incident Review

- Conduct post-incident review within 5 business days of resolution for P1/P2; within 10 days for P3
- Review attendees: AI Governance Lead, Model Owner, Engineering Lead, affected business leads
- Document: timeline, root cause, impact, response effectiveness, lessons learned
- Identify systemic improvements to prevent recurrence - update governance controls, monitoring, or training
- Lessons learned fed back into AI governance framework, training materials, and risk register
- Post-incident review report stored in governance documentation repository

4. Escalation Matrix

Severity	Notify Within	Notify Who	Actions
P1 -Critical	1 hour	AI Governance Lead · DPO · Senior Leadership · Legal	Suspend system; preserve evidence; assess regulatory notification; executive briefing
P2 - High	4 hours	AI Governance Lead · Model Owner · DPO (if data involved)	Contain outputs; investigate; suspend delivery if outputs unverified
P3 - Medium	24 hours	Model Owner · AI Governance team	Log incident; assign investigation; monitor for recurrence
P4 -Low	5 business days	Model Owner	Log and monitor; no immediate escalation

5. Roles During an Incident

Role	Responsibilities During Incident
AI Governance Lead	Overall incident commander for P1/P2. Approves containment and recovery actions. Signs off on return to operation. Owns post-incident review.
Incident Lead	Assigned per incident. Coordinates investigation, containment, and remediation. Maintains incident log. Communicates status updates.
Model Owner	Provides system knowledge. Executes technical containment and fix. Updates model card and risk register post-incident.

Role	Responsibilities During Incident
Data Protection Officer	Advises on personal data implications. Assesses regulatory notification requirements. Signs off on data-related remediation.
Engineering / ML Team	Technical investigation and root cause analysis. Implements and tests fixes. Preserves logs and evidence.
Legal & Compliance	Advises on regulatory and contractual obligations. Reviews communications to external parties. Supports regulatory notification if required.
Communications / HR (if needed)	Manages internal and external communications for significant incidents. Advises on employee-related implications.

6. Initial Incident Report Form

Complete and submit this form immediately upon detecting a potential AI incident. Do not delay pending investigation.

Date & Time Detected	
Reported By (Role)	
AI System Affected	
Description of Incident	
How Was It Detected?	[Automated alert / User report / Spot-check / Audit / Other]
Outputs or Actions Affected	
Users / Individuals Impacted (estimated)	
Immediate Actions Taken	
Does This Involve Personal Data?	[Yes / No / Unknown]
Proposed Severity (P1–P4)	
Submitted To	[AI Governance team contact — redacted]

7. Incident Investigation Record

Incident ID	[Auto-assigned by AI Governance team]
Confirmed Severity	[P1 / P2 / P3 / P4]
Incident Lead	[Role]
AI System	
Model Version	
Date Opened	
Date Resolved	

Root Cause Category	[Data quality / Model failure / Prompt-config error / Integration failure / Process gap / Human error / Unknown]
Root Cause Description	
Scope of Impact	[Number of outputs affected; users impacted; decisions made on incorrect output]
Containment Actions Taken	
Corrective Actions	
Governance Documents Updated	[Risk Register / Model Card / Validation Report / Policy - list all updated]
Lessons Learned	
Recurrence Prevention	
Regulatory Notification Required?	[Yes / No - if Yes, describe action taken]
Post-Incident Review Completed	[Yes / No - date]

8. Incident Log

ID	Date	System	Severity	Root Cause	Impact	Resolution	Status
INC-01							
INC-02							
INC-03							

9. Plan Maintenance & Testing

- This plan will be reviewed annually and after every P1 incident
- A tabletop exercise simulating a P1 AI incident will be conducted annually
- Contact details and escalation paths will be verified quarterly
- All staff involved in AI governance must be briefed on this plan as part of AI governance training

10. Sign-Off

Role	Name	Signature	Date
AI Governance Lead			
DPO			
Engineering Lead			
Legal & Compliance			
Senior Leadership			

11. Version History

Version	Date	Summary of Changes	Author
1.0	[Date]	Initial plan - generic cross-industry AI Incident Response Plan aligned to NIST AI RMF and ISO 42001	[Role]